

Course: GRC 102 - Information Security Governance

Assessment: Week 1 Practical Laboratory: Information Security Governance in Action

Student: Sisanda Lisa Masango

Registration Number: C11/26/CGRCE/17572

Date: 10 September 2026

Organisation: GlobalHealth Connect (GHC)

Role: Director of Information Security Governance

Submission: Written Report and Supporting Evidence

Executive Introduction

GlobalHealth Connect (GHC) is a growing health-technology organisation providing cloud-based patient-management systems. Its rapid expansion, acquisition of two smaller organisations and recent data-leakage near-miss have exposed weaknesses in its existing ad-hoc approach to information security governance. The Board has therefore identified the need to move from reactive security practices towards a structured, accountable and business-aligned governance programme.

This report establishes a governance framework designed to support GHC's strategic objectives while improving accountability, risk management, decision-making and executive oversight. The proposed approach is consistent with the governance emphasis of the NIST Cybersecurity Framework (CSF) 2.0, which places cybersecurity governance, organisational context, risk strategy, and roles and responsibilities at the centre of cybersecurity risk management (Pascoe et al., 2024). NIST describes the Govern function as establishing, communicating and monitoring an organisation's cybersecurity risk-management strategy, expectations and policy.

The report consists of five evidence bundles:

1. Governance Blueprint
2. Information Security Charter
3. Board Reporting and Security Metrics
4. Security Steering Committee
5. Governance Maturity Assessment and Improvement Roadmap

The overall objective is to establish governance that protects patient information and customer trust while enabling GHC's growth, innovation, operational efficiency and regulatory responsibilities.

Task 1 - Governance Blueprint

1.1: Current-State Governance Gap Assessment

GHC's current governance model can be characterised as reactive and fragmented. The organisation has security-related responsibilities distributed across IT, development, compliance, finance and HR, but the scenario does not identify a dedicated governance structure that brings these responsibilities together. The recent near-miss demonstrates that security decisions cannot remain primarily operational or department-specific.

NIST CSF 2.0 identifies governance as an explicit organisational function and highlights the importance of establishing organisational context, risk-management strategy, and clear roles, responsibilities and authorities (Pascoe et al., 2024).

Current-State gaps

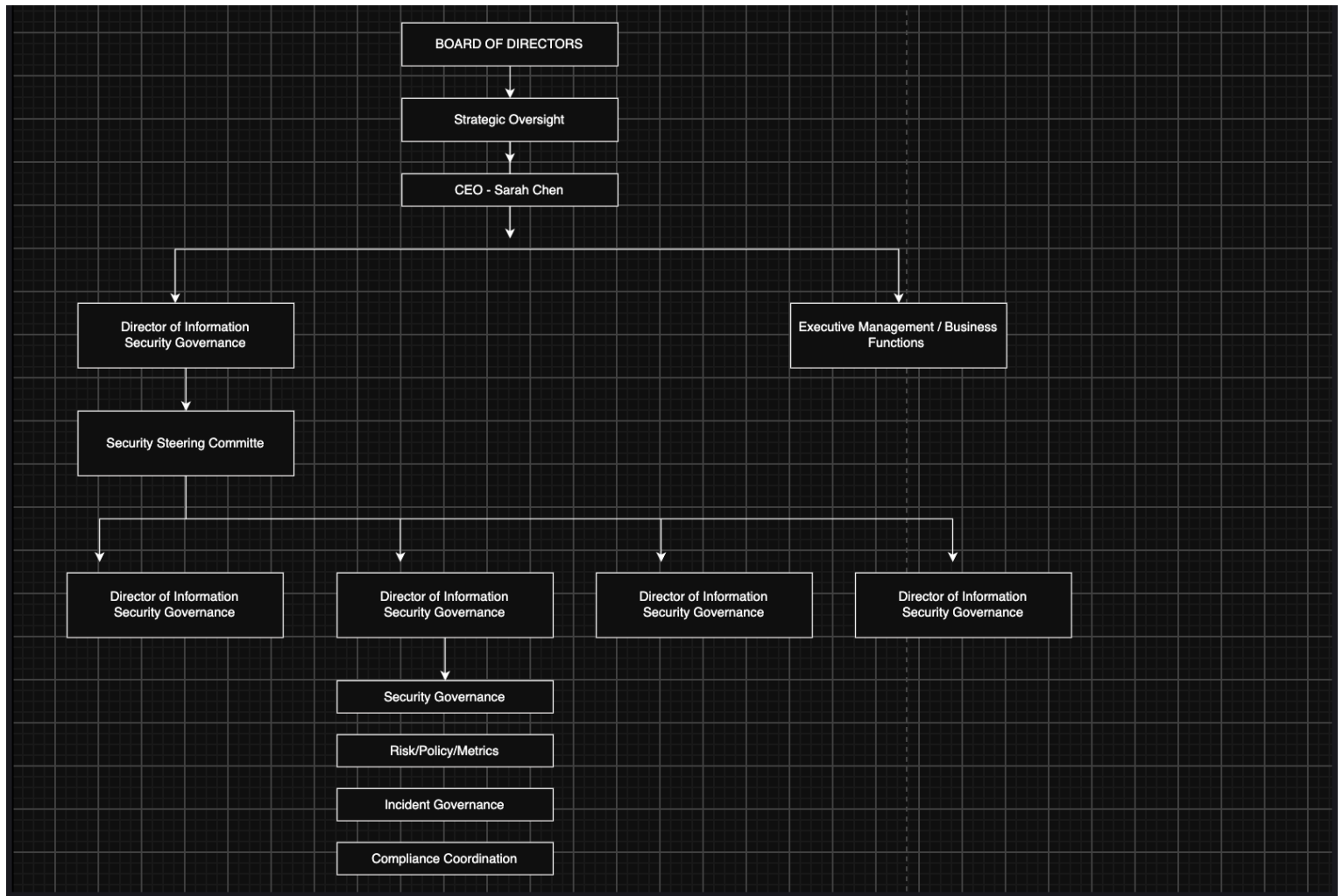
Governance Area	Current Weakness	Business Impact	Required Improvement
Security Ownership	Security activities are distributed across departments without a clearly defined governance owner.	Decisions may be delayed, duplicated or overlooked.	Establish a formal Information Security Governance function led by the Director of Information Security Governance.
Accountability	Existing roles perform security-related activities, but enterprise accountability is unclear.	Individuals may assume another department owns a risk or decision.	Establish formal accountability using RACI.
Policy Management	The organisation has an ad-hoc approach and acquisitions have created additional complexity.	Policies may be inconsistent or unsuitable for the current business.	Establish central policy ownership, approval and review.
Risk Management	The organisation is responding to events rather than systematically identifying and treating risks.	Emerging risks may remain unidentified until an incident occurs.	Establish an enterprise security risk register and regular risk review.
Executive reporting	Technical information is not consistently converted into business impact.	The Board cannot easily determine whether security investments are reducing risk.	Establish a concise Board security dashboard.

Cross-Functional decisions	The password-policy dispute demonstrates disagreement between technology and operational stakeholders.	Security controls may be implemented without sufficient business alignment.	Establish a cross-functional Security Steering Committee.
Incident governance	The recent data-leakage near-miss indicates a need for structured incident governance.	Future incidents could produce greater operational, financial or reputational consequences.	Establish formal incident-response planning, escalation and lessons-learned processes.
Training	Training is mandatory, but engagement is low.	Employees may remain a significant source of security exposure.	Introduce measurable awareness objectives and targeted training.
Compliance	Compliance activity is not yet described as an integrated governance capability.	Evidence may be gathered reactively for audits rather than continuously.	Establish continuous compliance monitoring and evidence ownership.

The gaps demonstrate that GHC's primary problem is not necessarily the absence of individual security activities; rather, it is the absence of an integrated system for directing, controlling, monitoring and improving those activities.

1.2 Proposed Governance Organisational Structure

The proposed structure establishes clear reporting and decision-making relationships.



Proposed reporting relationships

Board of Directors

The Board provides strategic oversight, approves the organisation's risk appetite and receives periodic security reporting. Its focus should remain on enterprise risk, customer trust, regulatory exposure, strategic objectives and material security decisions rather than operational technical details.

Chief Executive Officer - Sarah Chen

The CEO is accountable for ensuring that security governance supports GHC's strategic objectives, including growth, operational efficiency, reputation and accountability. The CEO also provides executive sponsorship for the governance programme.

Director of Information Security Governance

The Director owns the information security governance programme and coordinates policy, risk, reporting, governance assurance and cross-functional decision-making. The position should have sufficient authority to escalate material risks to executive management and the Board.

Security Steering Committee

The SSC provides cross-functional governance and acts as the main forum for resolving security decisions requiring business, technology and compliance input.

Business and Technology Functions

IT Operations, Development, Compliance, Finance and HR remain accountable for implementing security responsibilities within their respective areas.

This structure follows the principle that governance should connect cybersecurity decisions to organisational objectives rather than treating security as an isolated technical function. NIST CSF 2.0 specifically emphasises organisational context and roles, responsibilities and authorities within the Govern function (Pascoe et al., 2024).

1.3 RACI Matrix

Governance Activity	Board	CEO	Director IS Governance	IT Manager	Senior Developer	Compliance Officer	HR	CFO
Approve information security policy	I	A	R	C	C	C	I	C
Review enterprise security risks	I	A	R	C	C	C	I	C
Maintain security risk register	I	I	A/R	C	C	C	I	C
Incident response planning	I	A	R	R	C	C	C	I
Major incident escalation	I	A	R	R	C	C	C	I
Security awareness programme	I	A	R	C	I	C	R	I
Compliance monitoring	I	A	R	C	I	R	C	C
Board security reporting	A	C	R	C	C	C	I	C
Security investment prioritisation	A	A	R	C	C	C	I	R
Security policy review	I	A	R	C	C	R	C	I

The RACI model creates explicit accountability while maintaining cross-functional consultation. This is important because information security decisions can affect product development, employee workflows, compliance obligations and financial investment simultaneously.

NIST CSF 2.0 specifically identifies Roles, Responsibilities, and Authorities (GV.RR) as a governance category, supporting the use of clearly defined accountability structures (Pascoe et al., 2024).

1.4 Governance Rationale

The proposed model supports **accountability** by assigning an accountable owner to significant governance activities. It supports **transparency** because security decisions, risks, metrics and responsibilities are formally documented and escalated through defined reporting channels.

The structure also improves **business alignment** by involving the CEO, CFO, CTO/technology leadership, compliance and operational functions rather than allowing security decisions to be made exclusively by IT. This is particularly important because GHC's strategic goals include market expansion, operational efficiency, customer trust, innovation and regulatory excellence.

Finally, the structure supports **risk management** by creating a repeatable process for identifying, assessing, treating, monitoring and escalating information-security risks. ISO/IEC 27001 describes an information security management system as a structured approach for establishing, implementing, maintaining and continually improving information security risk management (International Organization for Standardization [ISO], 2022).

Task 2 - Information Security Charter

2.1 Global Health Connect Information Security Charter

Purpose

The purpose of the GHC Information Security Programme is to protect the confidentiality, integrity and availability of information and technology resources while supporting the organisation's strategic objectives.

The programme will enable GHC to:

- protect patient and customer information;
- maintain customer trust;
- support secure business growth;
- enable innovation;
- improve operational resilience;
- meet applicable legal, regulatory and contractual obligations; and
- establish consistent security governance across GHC and its acquired organisations.

This approach reflects the principle that information security should be integrated into organisational risk management rather than treated solely as a technical control function. ISO/IEC 27001 provides a structured framework for managing information-security risks and continually improving an ISMS (ISO, 2022).

Scope

The Information Security Programme applies to:

- GHC employees and contractors;
- information systems and cloud services;
- patient-management platforms;
- corporate and financial information;
- development environments;
- infrastructure and operational technology used to provide services;
- information-security processes;
- third-party suppliers handling GHC information;
- acquired businesses and their relevant systems;
- information assets throughout their lifecycle; and
- security-related policies, standards and procedures.

Authority

The Information Security Programme derives its authority from the GHC Board and executive management.

The Director of Information Security Governance is authorised to:

1. establish and maintain the security governance framework;
2. coordinate security risk assessments;
3. require responsible business functions to address identified security risks;
4. escalate unresolved material risks to the CEO and Board;
5. coordinate security-policy development;
6. establish security reporting requirements;
7. convene or escalate matters through the Security Steering Committee; and
8. recommend security investments and risk treatments.

Material risks that exceed approved risk tolerance should be escalated to executive management and, where appropriate, the Board.

Roles and Responsibilities

Board

- Provides strategic oversight.
- Approves or oversees risk appetite.
- Receives material security and risk reporting.
- Holds executive management accountable for security governance.

CEO

- Provides executive sponsorship.
- Ensures security supports business strategy.
- Resolves significant cross-functional governance issues.

Director of Information Security Governance

- Owns the governance programme.
- Coordinates security policy and risk management.
- Maintains governance reporting.

- Coordinates the Security Steering Committee.
- Escalates significant security risks.

CFO

- Evaluates security investment against business risk.
- Supports prioritisation of security expenditure.
- Oversees financial implications of major security risks.

IT Manager

- Implements and maintains operational security controls.
- Supports incident response and technical remediation.
- Reports operational risks and control weaknesses.

Senior Developer

- Integrates security into product development.
- Supports secure development practices.
- Advises on the operational impact of security controls.

Compliance Officer

- Coordinates applicable regulatory and compliance obligations.
- Supports compliance monitoring and evidence collection.
- Advises on regulatory risk.

HR Manager

- Supports security awareness.
- Ensures security responsibilities are integrated into employee lifecycle processes.

Key Principles

GHC's Information Security Programme will operate according to the following principles:

1. **Risk-based:** Security decisions will be prioritised according to business risk.
2. **Business-aligned:** Security should enable GHC's strategic objectives rather than unnecessarily obstruct them.
3. **Proportionate:** Controls should reflect the level of risk and business impact.
4. **Accountable:** Every significant security activity should have a clearly identified owner.
5. **Consistent:** Acquired organisations should progressively align with GHC's governance framework.
6. **Transparent:** Material risks and security performance should be communicated to appropriate stakeholders.
7. **Continuously improving:** Governance processes should be reviewed and improved based on performance, incidents and changing risks.
8. **Security by design:** Security considerations should be incorporated into business and technology decisions early rather than after implementation.

Reporting Structure

Security governance reporting will operate at three levels:

Operational level:

Regular reporting to management regarding incidents, vulnerabilities, training, policy compliance and remediation.

Executive level:

Regular Security Steering Committee reporting regarding material risks, policy decisions, security investment and programme performance.

Board level:

Periodic reporting focused on enterprise risk, customer trust, material incidents, security posture, regulatory exposure, strategic initiatives and investment decisions.

Review and Approval

The Charter shall be approved by the CEO and appropriate executive governance authority, with Board oversight.

The Charter shall be reviewed at least annually and whenever there is a material change to GHC's business, risk profile, regulatory obligations, technology environment or organisational structure.

Changes to the Charter must be documented, approved and communicated to relevant stakeholders.

CFO Justification Memo

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Subject: Justification for the GHC Information Security Charter

The proposed Information Security Charter establishes a formal mandate for GHC's security programme and directly supports the organisation's 2026 strategic goals. GHC intends to increase its client base by 25%, enter two regional markets, reduce overhead, achieve 99.99% system uptime, protect customer trust, invest in AI-enabled capabilities and proactively address regulatory obligations. These objectives increase the importance of consistent information-security governance because growth, acquisitions and innovation expand the organisation's information-security risk exposure.

From an investment perspective, the Charter creates accountability for security expenditure by linking security activities to identified business risks and strategic priorities. Rather than treating security as an open-ended technical cost, GHC can use the Charter, risk register and Board metrics to prioritise investments according to business impact, regulatory exposure, customer trust and operational resilience. This supports informed resource allocation and provides management with a clearer basis for determining whether security investments are reducing material risks.

Task 3 - Board Reporting and Security Metrics

Board Executive Summary

GlobalHealth Connect – Information Security Executive Summary

Overall Security Posture: RED

GHC's overall security posture should currently be assessed as Red because the six-month dataset shows deterioration across multiple indicators rather than improvement. Phishing attempts increased from 150 in September to 320 in February, malware increased from 25 to 50, the proportion of critical vulnerabilities patched decreased from 67% to 55%, and high-risk incidents increased from 2 to 7. Although training completion improved from 45% to 70%, the overall trend indicates that GHC's risk exposure is increasing faster than its control performance.

The most significant Board concern is the combination of **increasing threat activity, declining critical-vulnerability remediation performance and increasing high-risk incidents**. The situation is inconsistent with GHC's objective of maintaining customer trust and achieving zero major data breaches.

Immediate Board priorities:

1. Strengthen critical-vulnerability remediation and establish executive oversight of overdue critical vulnerabilities.
2. Investigate the drivers behind the increase in high-risk incidents.
3. Continue increasing security-awareness effectiveness while moving beyond completion-based training.
4. Establish clear ownership and escalation for security risks.
5. Monitor whether security investment is producing measurable reductions in business risk.

Five Board-Level Security Metrics

Metric 1 - High Risk Incidents

Month	Incidents
September	2
October	3
November	4
December	5
January	6
February	7

Trend: Increasing continuously.

Board commentary:

High-risk incidents increased from 2 to 7 over six months, representing a 250% increase. This is the most direct indicator in the dataset that material security events are becoming more frequent. The Board should require management to identify the primary causes, business impact and corrective actions associated with these incidents.

Metric 2 - Critical Vulnerabilities Patched

Month	Patched
September	10/15= 67%
October	12/20 = 60%
November	15/25 = 60%
December	18/30 = 60%
January	20/35 = 57%
February	22/40 = 55%

Trend: Declining.

Board commentary:

The percentage of critical vulnerabilities patched declined from 67% to 55%, while the absolute number of critical vulnerabilities increased from 15 to 40. This creates a material governance concern because the organisation is not keeping pace with its critical remediation workload. Management should establish clear remediation targets and escalation for overdue critical vulnerabilities.

NIST's cybersecurity guidance emphasises identifying and managing cybersecurity risk as part of an integrated organisational risk-management process (Pascoe et al., 2024).

Metric 3 - Phishing Activity

Month	Phishing Events
September	150
October	180
November	210
December	150
January	280
February	320

Trend: Strongly increasing.

Board commentary:

Phishing activity increased by approximately 113% from September to February. Although increased detection could partly contribute to the observed growth, the dataset alone does not establish the cause. Management should therefore investigate whether the increase represents greater external threat activity, improved detection, or both.

The Board should view this metric alongside training performance and incident trends rather than interpreting it in isolation.

Metric 4 - Security Training Completion

Month	Training Completion
September	45%
October	50%
November	55%
December	60%
January	65%
February	70%

Trend: Improving.

Board commentary:

Training completion improved consistently from 45% to 70%. This is a positive trend, but the organisation should avoid interpreting completion as proof that employee behaviour has improved. The continued increase in phishing activity and high-risk incidents indicates that training effectiveness should be assessed alongside behavioural and incident outcomes.

Metric 5 - Malware Events

Month	Malware Events
September	25
October	30
November	35
December	40
January	45
February	50

Trend: Increasing continuously.

Board commentary:

Malware events doubled from 25 to 50. The Board should require management to determine whether this reflects increased attempted attacks, increased detection capability, or a genuine deterioration in the threat environment. The metric is particularly useful when considered together with vulnerability remediation and high-risk incidents.

Priority Risks and Recommendations

Priority Risk 1 – Increasing High-Risk Incidents

Risk: High-risk incidents increased from 2 to 7.

Business impact: Continued growth in high-risk incidents could threaten customer trust, operational continuity and sensitive information.

Recommendation: Establish an executive-owned incident trend review. Each high-risk incident should be assigned an accountable owner, root cause, corrective action and target completion date.

NIST's current incident-response guidance recommends integrating incident response throughout cybersecurity risk management to improve preparedness and reduce the impact of incidents (Nelson et al., 2025).

Priority Risk 2 – Declining Critical-Vulnerability Remediation

Business impact: Unresolved critical vulnerabilities may increase the likelihood and potential impact of security incidents.

Recommendation: Establish a Board-approved remediation target and require escalation of overdue critical vulnerabilities to the Security Steering Committee and executive management.

Recommendation 3 – Strengthen Security Governance

GHC should implement the proposed governance structure, RACI model and Security Steering Committee to ensure that security risks have clearly defined owners and escalation paths.

Recommendation 4 – Improve Awareness Effectiveness

GHC should continue increasing training completion while introducing measures that evaluate whether awareness reduces risky behaviour and contributes to lower incident exposure.

Rationale for Metric Selection

The five selected metrics provide a balanced view of GHC's security posture:

Metric	Why the Board Needs it
High-risk incidents	Shows whether material security events are increasing or decreasing.
Critical vulnerabilities patched	Measures management's ability to address significant technical risk.
Phishing	Provides visibility into an important external threat affecting employees and information.
Training completion	Indicates progress in employee awareness.

Malware	Provides a high-level indicator of malicious activity affecting the organisation.
---------	---

These metrics were selected because they are understandable to non-technical executives and can be linked to decisions concerning risk, investment, resilience and customer trust.

Task 4 - Security Steering Committee

Purpose

The Security Steering Committee (SSC) is a cross-functional governance body established to provide strategic direction, prioritisation and oversight of GHC's information-security programme.

The SSC exists to ensure that security decisions reflect business, technology, compliance and operational requirements.

Scope

The SSC will consider:

- information-security risks;
- security policies and standards;
- security investment priorities;
- major security incidents;
- compliance and regulatory risks;
- security awareness;
- vulnerability and risk-remediation priorities;
- third-party security concerns;
- acquisition-related security integration;
- security implications of new technology and innovation; and
- matters escalated by business or technology functions.

Membership

Chair: Director of Information Security Governance

Permanent members:

- CEO or CEO delegate
- CFO
- CTO / technology leadership
- IT Manager – John Smith
- Senior Developer – Jane Doe
- Compliance Officer – Mark Johnson
- HR Manager – Robert Green

Advisory participants when required:

- Finance representative – Emily White
- Legal advisers
- Product representatives
- External specialists
- Incident-response representatives

Responsibilities

The SSC shall:

1. review significant security risks;
2. approve or recommend security priorities;
3. resolve cross-functional security disputes;
4. review security metrics;
5. monitor remediation of significant risks;
6. oversee major policy decisions;
7. review significant incidents and lessons learned;
8. ensure security supports business strategy;
9. monitor governance maturity; and
10. escalate material matters to the CEO and Board.

Meeting Cadence

The SSC will meet **monthly**, with additional meetings convened for significant incidents or urgent governance decisions.

A quarterly summary will be provided to executive management and the Board.

Decision Authority

The SSC may make decisions within its delegated authority and recommend matters requiring executive or Board approval.

Decisions involving significant financial commitments, material changes to risk appetite, major business disruption or strategic risk acceptance shall be escalated to the appropriate executive authority.

Reporting

The SSC Chair will maintain meeting records, decisions, action owners and due dates.

Material risks and unresolved decisions will be escalated to the CEO.

Board reporting will include significant risks, material incidents, key security metrics and major programme decisions.

First SSC Meeting Agenda

Security Steering Committee – Inaugural Meeting

Chair: Director of Information Security Governance

Duration: 90 minutes

Agenda

1. Welcome and purpose – 10 minutes

- Confirm SSC mandate.
- Confirm membership.
- Confirm decision-making principles.

2. Current GHC security posture – 10 minutes

- Recent data-leakage near-miss.
- Governance gaps.
- Current security metrics.

3. Password-policy conflict – 25 minutes

Current proposal:

16-character complex passwords changed every 30 days without password-manager integration.

CTO position:

The policy may create excessive user friction and recommends greater emphasis on multi-factor authentication and secure password management.

IT Manager position:

Stronger password controls are necessary to reduce security risk.

Discussion questions:

- What risk is the proposed policy attempting to address?
- Is the proposed control proportionate to that risk?
- What usability consequences would result?
- Could MFA reduce reliance on password complexity?
- Could password-manager integration reduce user friction?
- What implementation and monitoring requirements would be necessary?

4. Decision and action plan – 15 minutes

- Agree preferred policy direction.
- Assign accountable owner.
- Define implementation timeline.
- Define measures of effectiveness.

5. Risk and governance priorities – 15 minutes

- Critical vulnerability remediation.
- High-risk incident trend.
- Security awareness.
- Policy harmonisation following acquisitions.

6. Board reporting requirements – 10 minutes

- Confirm five metrics.
- Confirm reporting cadence.
- Confirm escalation thresholds.

7. Close and actions – 5 minutes

- Confirm action owners.
- Confirm deadlines.
- Confirm next meeting.

CEO Briefing Note

To: Sarah Chen, Chief Executive Officer

From: Director of Information Security Governance

Subject: Establishment of the Security Steering Committee

The Security Steering Committee will provide GHC with a formal mechanism for resolving security decisions that cross departmental boundaries. The current password-policy disagreement demonstrates why security decisions cannot be considered solely from an IT perspective. A control may reduce technical risk while simultaneously affecting productivity, employee experience, development and operational efficiency. The SSC therefore brings together technology, compliance, finance, HR and executive leadership to assess security decisions against GHC's wider business objectives.

In the password-policy case, the SSC should avoid treating the disagreement as a choice between "strong security" and "weak security." Instead, it should identify the underlying risk and evaluate alternative control combinations. For example, the CTO's recommendation to strengthen multi-factor authentication and password management could be evaluated alongside password requirements to determine whether equivalent or better risk reduction can be achieved with less operational friction. The resulting decision should have a clear owner, implementation plan and success measure.

The SSC therefore becomes an important governance mechanism for maintaining strategic alignment. It ensures that security decisions are evidence-based, risk-based and transparent while providing a defined route for escalation when cross-functional agreement cannot be reached.

Task 5 - Governance Maturity Assessment

The assessment brief provides a five-level maturity model ranging from **Level 1 – Ad Hoc** to **Level 5 – Optimising**. Level 3, Defined, requires documented, standardised and communicated processes supported by clear responsibilities.

Current Maturity Assessment

Domain	Current Level	Assessment	Target
Policy & Documentation	2 – Initial	Policies exist but are inconsistent, inherited from acquisitions and not always current.	Level 3
Roles & Responsibilities	1 – Ad Hoc	Security ownership and accountability are unclear.	Level 3
Risk Management	1 – Ad Hoc	Organisation is reactive and lacks a formal proactive assessment process.	Level 3
Metrics & Reporting	2 – Initial	Technical metrics exist but are not consistently translated into business impact.	Level 3
Training & Awareness	2 – Initial	Training is mandatory, but engagement remains low.	Level 3
Compliance	2 – Initial	Compliance is primarily audit-driven rather than continuously monitored.	Level 3

Overall maturity: Level 2 – Initial, with several Level 1 characteristics

GHC has some security processes and activities in place, but these are inconsistent and insufficiently integrated. The strongest evidence of this is the combination of inconsistent policies, unclear ownership, reactive risk management, weak business-oriented reporting, low awareness engagement and audit-driven compliance.

GHC should therefore focus on achieving **Level 3 – Defined** before attempting to move towards Level 4 or 5. This is consistent with the Board's request for a realistic 12–18 month programme rather than an unrealistic attempt to achieve optimisation immediately.

12–18 Month Governance Improvement Roadmap

Initiative 1 – Establish the Governance Framework

Timeline: Months 1–3

Objective: Establish clear security ownership, authority and governance processes.

Key activities:

- Approve Information Security Charter.
- Establish a Security Steering Committee.
- Approve RACI matrix.
- Define reporting relationships.
- Establish policy ownership.
- Define risk-escalation procedures

Expected measurable outcome:

- 100% of major governance activities assigned an accountable owner.
- SSC established and meeting monthly.
- Charter approved and communicated.
- Governance RACI formally adopted.

Initiative 2 - Establish Formal Security Risk Management

Timeline: Months 2–6

Objective: Move GHC from reactive risk management to a repeatable risk-assessment process.

Key activities:

- Create enterprise security risk register.
- Define risk assessment methodology.
- Identify major information-security risks.
- Assign risk owners.
- Define treatment plans.
- Establish monthly risk review.

Expected measurable outcome:

- 100% of identified material security risks have owners.
- Material risks have documented treatment plans.
- Risk register reviewed monthly.
- Material unresolved risks escalated according to defined criteria.

Initiative 3 - Harmonise Policies and Acquisition Governance

Timeline: Months 3–9

Objective: Establish a consistent security-policy baseline across GHC and acquired organisations.

Key activities:

- Inventory existing policies.
- Identify conflicting or outdated policies.
- Establish common policy structure.
- Assign policy owners.
- Approve minimum security requirements.

- Establish annual review cycle.

Expected measurable outcome:

- 100% of critical security policies reviewed.
- All acquired organisations mapped to the GHC policy baseline.
- Policy owners identified.
- Formal review and approval process operational.

Initiative 4 - Establish Board Metrics and Security Performance Reporting

Timeline: Months 4–9

Objective: Convert technical security information into business-focused reporting.

Key activities:

- Define Board metrics.
- Establish data owners.
- Define reporting frequency.
- Establish thresholds for Red/Amber/Green status.
- Link metrics to risks and business outcomes.
- Produce quarterly Board reporting.

Expected measurable outcome:

- Five agreed Board-level security metrics operational.
- Quarterly reporting delivered.
- Material risk trends linked to recommendations.
- Board receives concise decision-oriented reporting.

Initiative 5 - Strengthen Security Awareness and Continuous Improvement

Timeline: Months 6–18

Objective: Improve employee security behaviour and embed continual improvement.

Key activities:

- Continue awareness training.
- Introduce targeted awareness activities.
- Monitor training completion.
- Evaluate behavioural indicators.
- Review security incidents for lessons learned.
- Conduct periodic governance maturity reassessments.

Expected measurable outcome:

- Training completion reaches a defined organisational target.
- Awareness metrics reviewed quarterly.
- Major incidents produce documented lessons learned.
- Governance maturity reassessed at months 12 and 18.

Roadmap Summary

Period	Main Focus	Key Deliverables
Months 1–3	Governance foundation	Charter, RACI, SSC, ownership
Months 2–6	Risk management	Risk methodology, risk register, risk owners
Months 3–9	Policy harmonisation	Policy baseline and acquisition integration
Months 4–9	Board reporting	Metrics, RAG dashboard, reporting process
Months 6–18	Continuous improvement	Awareness, lessons learned, maturity reassessment

The roadmap deliberately prioritises **governance foundations before optimisation**. Attempting to implement advanced measurement and continuous improvement before establishing ownership, policies and risk processes would create additional complexity without resolving the underlying governance weaknesses.

Board Executive Summary

GHC's current information-security governance maturity is assessed at approximately **Level 2 – Initial**, with Roles & Responsibilities and Risk Management displaying Level 1 characteristics. Policies are inconsistent, security ownership is unclear, risk management is reactive, technical metrics are not consistently translated into business impact, employee engagement with training is low and compliance remains largely audit-driven.

The proposed 12–18 month roadmap focuses on establishing the foundations necessary to achieve **Level 3 – Defined** across all six domains. The programme prioritises governance structure, accountability, risk management, policy harmonisation, Board reporting and awareness. Achieving Level 3 will provide GHC with documented, standardised and communicated processes supported by clear responsibilities, which is the maturity level specified by the assessment brief.

The strategic importance of the roadmap is that GHC's security governance must mature at the same time as the organisation itself. Continued growth, acquisitions, AI-driven innovation and expansion into new markets increase the need for consistent governance. A defined governance model will enable GHC to make security decisions based on business risk, improve executive accountability, provide the Board with meaningful information and protect customer trust while supporting innovation.

Conclusion

GHC's recent growth, acquisitions and data-leakage near-miss demonstrate that an informal security model is no longer appropriate for the organisation's risk profile. The central governance challenge is not simply implementing additional technical controls; it is creating a

system through which security responsibilities, decisions, risks, policies and performance are consistently directed and overseen.

The proposed governance structure addresses this challenge by establishing clear accountability between the Board, CEO, Information Security Governance function, Security Steering Committee and operational departments. The RACI model further clarifies ownership and reduces ambiguity.

The Information Security Charter provides the formal mandate necessary to establish the programme, while the Board reporting model translates security information into business-relevant indicators. The five selected metrics demonstrate that GHC currently faces an unfavourable security trend, particularly regarding high-risk incidents, critical vulnerability remediation, phishing and malware activity.

The Security Steering Committee provides a practical mechanism for resolving cross-functional security decisions and ensuring that security controls remain aligned with business requirements. Finally, the maturity assessment establishes that GHC should focus on achieving Level 3 – Defined before pursuing higher maturity levels.

Together, these measures transform GHC's security programme from a reactive collection of activities into a structured governance capability. The proposed 12–18 month roadmap provides a realistic sequence for establishing accountability, formalising risk management, harmonising policies, improving Board reporting and embedding continuous improvement.

References

International Organization for Standardization. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection—Information security management systems—Requirements*. ISO. [ISO/IEC 27001:2022](#)

ISACA. (2019). *COBIT 2019 framework: Governance and management objectives*. ISACA. [COBIT resources](#)

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST Special Publication 800-61 Rev. 3). National Institute of Standards and Technology. [NIST SP 800-61 Rev. 3](#)

Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). National Institute of Standards and Technology. [NIST Cybersecurity Framework 2.0](#)

International Cybersecurity and Digital Forensics Academy. (2026). *GRC102 Practical Laboratory: Information Security Governance in Action – GlobalHealth Connect (GHC) Executive Governance Simulation* [Controlled academic assessment brief].

AI assistance declaration

Generative AI was used as a language-support and drafting aid during the preparation of this assessment. I reviewed, evaluated, adapted and verified the resulting material against the assessment brief and relevant sources and remained responsible for the accuracy, reasoning, originality and final submitted work.